Université Tek-Up

Classe : ING5-SSIRF-D – Année universitaire 2026/2027

Sécurisation de Réseau et d'une application Web

FortiGate, VPN IPsec, OSPF et WAF F5 BIG-IP

Maquette EVE-NG avec DVWA et Kali Linux

Réalisé par :

Jebali Aziz

Jebali Hamza

Encadrant :

Mr.Bakkali Oussema

Rubrique	Détail
Matière	Art de la protection de secret
Plateforme de simulation	EVE-NG sur VMware
Technologies	FortiGate, IPsec, OSPF, F5 BIG-IP (LTM/ASM), DVWA, Kali Linux

Table des matières

1 Introduction **3**
1.1 Objectifs du projet 3
1.2 Organisation du rapport 3
2 Étude théorique **3**
2.1 Sécurité des applications Web 3
2.2 Technologies de protection 4
2.3 Outils de test 4
3 Architecture du projet **5**
3.1 Topologie générale 5
3.2 Plan d'adressage 5
3.3 Rôle des équipements 6
4 Réalisation **6**
4.1 Interconnexion et routage OSPF 6
4.2 Tunnel VPN IPsec entre les deux sites 7
4.3 Déploiement de l'application DVWA 8
4.4 Machines d'attaque Kali Linux 8
4.5 Intégration du F5 BIG-IP 8
4.6 Politique de sécurité applicative (ASM) 9
5 Tests et résultats **10**
5.1 Scénarios de test 10
5.2 Attaques réalisées 10
5.3 Résultats sans WAF : le VPN ne suffit pas 11
5.4 Résultats avec le WAF F5 BIG-IP 11
5.5 Preuves et journalisation 11
6 Difficultés rencontrées et solutions **12**
7 Limites et perspectives **12**
7.1 Limites de la maquette 12
7.2 Perspectives 13
8 Conclusion **13**
Références **13**

1 Introduction

Les applications Web sont exposées en permanence sur le réseau et manipulent des données sensibles ; elles constituent de ce fait une cible privilégiée. Les attaques les plus fréquentes (injections SQL, Cross-Site Scripting, injection de commandes, force brute) exploitent le plus souvent un manque de validation des entrées ou une configuration incorrecte. Se protéger efficacement suppose une défense en profondeur : sécuriser l'infrastructure réseau (pare-feu, routage, VPN) mais aussi inspecter le trafic au niveau applicatif avec un pare-feu applicatif (WAF).

Ce projet, réalisé dans le cadre du stage au sein de OneTECH Business Solutions, consiste à construire une maquette sur EVE-NG qui interconnecte deux sites par des pare-feu FortiGate (routage OSPF et tunnel VPN IPsec), à y héberger l'application volontairement vulnérable DVWA, à reproduire des attaques depuis Kali Linux, puis à placer un F5 BIG-IP équipé du module ASM devant l'application pour bloquer ces attaques.

1.1 Objectifs du projet

- Interconnecter un routeur central et deux sites distants (Site A et Site B) avec des pare-feu FortiGate et un routage dynamique OSPF en Area 0.
- Sécuriser les échanges entre les deux sites par un tunnel VPN IPsec (IKEv2).
- Déployer DVWA et reproduire les principales attaques Web (SQL Injection, XSS, Command Injection, File Inclusion, CSRF, File Upload, Brute Force).
- Démontrer qu'un VPN chiffre le transport mais ne protège pas l'application contre une attaque lancée depuis un site autorisé.
- Déployer F5 BIG-IP (LTM et ASM) en reverse proxy devant DVWA, bloquer les attaques et conserver des preuves dans les journaux.

1.2 Organisation du rapport

Le chapitre 2 rappelle les notions théoriques issues de la recherche bibliographique. Le chapitre 3 présente l'architecture et le plan d'adressage. Le chapitre 4 décrit la réalisation (routage, VPN, DVWA, F5 BIG-IP). Le chapitre 5 expose les tests et les résultats avant et après le WAF. Le chapitre 6 résume les difficultés rencontrées, le chapitre 7 les limites et perspectives, puis le chapitre 8 conclut.

2 Étude théorique

2.1 Sécurité des applications Web

La sécurité de l'information repose sur le triptyque CIA. Une compromission d'application Web peut entraîner un vol de données, une indisponibilité du service ou une atteinte à la réputation de l'entreprise. Le référentiel OWASP Top 10 liste les dix risques applicatifs les plus critiques.

Pilier	Définition
Confidentialité	L'information n'est accessible qu'aux personnes autorisées.
Intégrité	L'information n'est pas modifiée de façon non autorisée.
Disponibilité	L'information et les services restent accessibles aux utilisateurs légitimes.

Tableau 1 – Triptyque CIA

Attaque	Principe	Prévention
SQL Injection	Insertion de code SQL dans un champ non filtré pour contourner l'authentification ou extraire des données.	Requêtes préparées, validation des entrées, WAF

Attaque	Principe	Prévention
XSS (Reflected, Stored, DOM)	Injection d'un script exécuté dans le navigateur de la victime ; renvoyé, stocké ou purement côté client.	Encodage des sorties, validation, WAF
Command Injection	Exécution de commandes système via des données utilisateur transmises à une fonction système.	Éviter les appels système, liste blanche
File Inclusion (LFI/RFI)	Inclusion d'un fichier local ou distant ; le RFI est généralement plus critique.	Liste blanche de fichiers, désactiver l'inclusion distante
File Upload	Téléversement d'un fichier malveillant lorsque type et contenu ne sont pas contrôlés.	Contrôle des extensions et du contenu
CSRF	Exploitation de la confiance du site envers un utilisateur authentifié.	Jetons anti-CSRF, vérification de l'origine
Brute Force	Test automatisé de combinaisons d'identifiants et de mots de passe.	Limitation des tentatives, verrouillage, MFA

Tableau 2 – Principales attaques Web étudiées

2.2 Technologies de protection

Un **WAF** est placé entre les utilisateurs et l'application ; il agit en reverse proxy et inspecte chaque requête HTTP/HTTPS (couche 7). Il peut suivre un modèle positif (liste blanche des comportements autorisés) ou négatif (blocage par signatures d'attaques connues). Ses avantages sont la protection en temps réel et la couverture de l'OWASP Top 10 ; ses limites sont le risque de faux positifs et le fait qu'il ne remplace pas un développement sécurisé.

Technologie	Rôle dans le projet
FortiGate (Fortinet)	Pare-feu avec inspection d'état, NAT, Security Policies, routage OSPF et terminaison des tunnels VPN IPsec.
VPN IPsec	Sécurise les communications au niveau réseau. Phase 1 IKE : canal authentifié ; Phase 2 : négociation des clés ; ESP chiffre et authentifie les données.
OSPF	Protocole à état de liens : chaque routeur construit une LSDB identique et calcule les chemins par l'algorithme SPF (Dijkstra). L'Area 0 est le backbone.
WAF	Inspection du trafic HTTP en couche 7, blocage des requêtes malveillantes, journalisation.
F5 BIG-IP	Plateforme TMOS : reverse proxy, répartition de charge, SSL offloading, health monitoring et WAF (Advanced WAF / ASM).

Tableau 3 – Technologies de protection

Module F5	Rôle
LTM	Répartition de charge (Local Traffic Manager)
Advanced WAF (ex-ASM)	Protection des applications Web
APM	Gestion des accès et authentification
AFM	Pare-feu réseau (couches 3 et 4)
DNS	Sécurisation et répartition du trafic DNS

Tableau 4 – Modules de la plateforme BIG-IP

2.3 Outils de test

DVWA (Damn Vulnerable Web Application) est une application PHP/Apache/MySQL volontairement vulnérable, qui propose quatre niveaux de sécurité (Low, Medium, High, Impossible). **Kali Linux** est une distribution dédiée aux tests d'intrusion.

Outil	Usage
Nmap	Découverte d'hôtes, de ports et de services
Burp Suite	Interception et analyse du trafic HTTP
SQLMap	Détection et exploitation automatisée des injections SQL
Hydra	Attaques par force brute sur divers protocoles
Nikto	Scan de vulnérabilités Web

Tableau 5 – Outils de Kali Linux utilisés

3 Architecture du projet

3.1 Topologie générale

La maquette EVE-NG comprend un routeur central (FortiGate) relié à deux pare-feu de bordure, FGT-2 pour le Site A et FGT-3 pour le Site B, ainsi qu'à une machine Kali externe. Le serveur DVWA est hébergé sur le Site A derrière le F5 BIG-IP, lui-même relié à FGT-2 par une DMZ. Un second Kali, placé sur le Site B, permet de simuler un attaquant interne passant par le tunnel VPN.

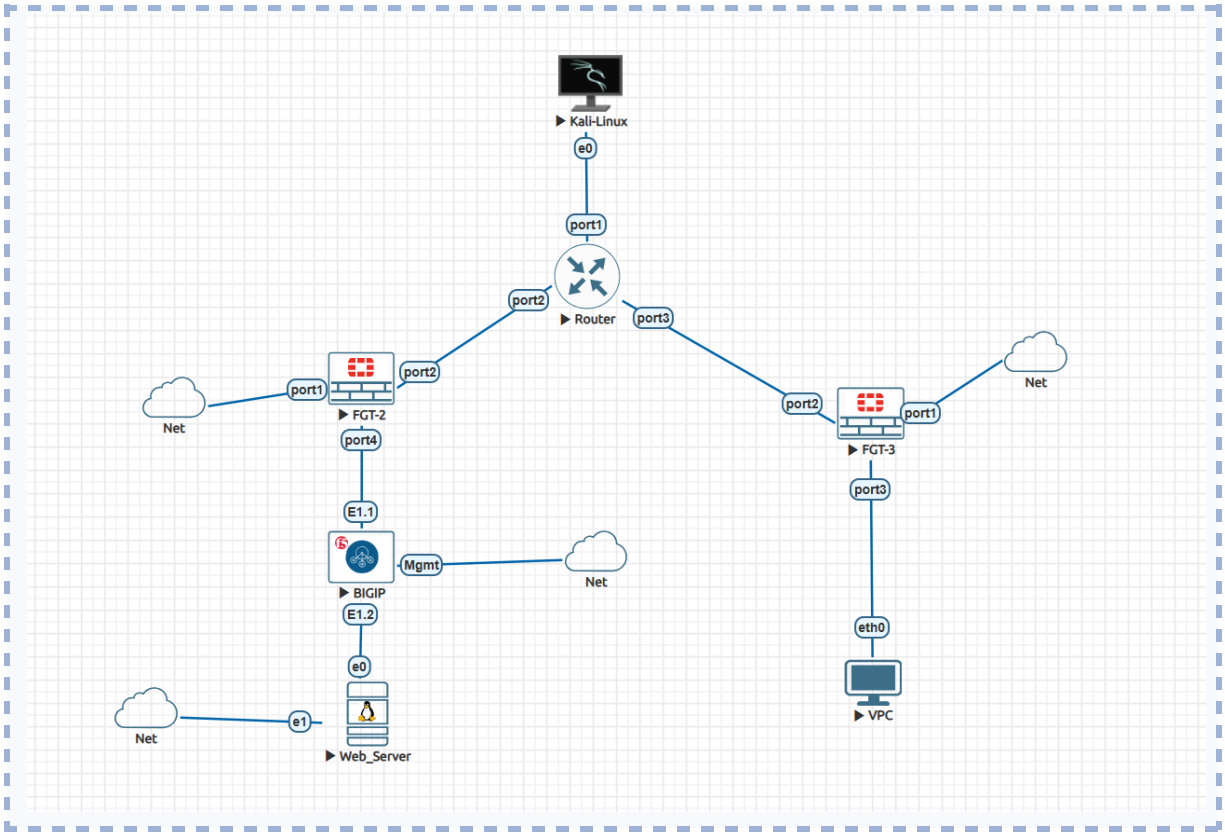


Figure 1 – Architecture générale du projet

3.2 Plan d'adressage

Équipement	Interface	Adresse	Rôle
Router	port1	10.10.10.1/24	Vers Kali externe
Router	port2	5.2.1.1/24	Vers FGT-2 (OSPF)
Router	port3	5.2.2.1/24	Vers FGT-3 (OSPF)
Router	port4	192.168.227.140/24	Management
FGT-2	port2	5.2.1.2/24	WAN vers Router

Équipement	Interface	Adresse	Rôle
FGT-2	port4	172.30.10.1/24	DMZ vers F5 BIG-IP
FGT-2	port3	172.30.1.1/24	LAN Site A
FGT-3	port2	5.2.2.2/24	WAN vers Router
FGT-3	port3	172.30.2.1/24	LAN Site B (VPCS 172.30.2.5)
FGT-3	port4	172.30.3.1/24	Segment Kali Site B
F5 BIG-IP	1.1 (external)	172.30.10.2/24	Self IP DMZ ; VIP 172.30.10.100:80
F5 BIG-IP	1.2 (internal)	172.30.1.10/24	Self IP vers DVWA
F5 BIG-IP	mgmt	192.168.227.170/24	Management
DVWA (Ubuntu)	ens3 / ens4	172.30.1.5/24 ; 192.168.227.155/24	Serveur Web / management
Kali externe	eth0	10.10.10.10/24	Attaquant externe
Kali Site B	eth0	172.30.3.10/24	Attaquant interne

Tableau 6 – Plan d'adressage de la maquette

3.3 Rôle des équipements

Équipement	Rôle
Router (FortiOS)	Routeur central : relie Kali externe, FGT-2 et FGT-3 ; policies de transit et routes statiques.
FGT-2 / FGT-3	Pare-feu de bordure des sites ; OSPF, tunnel IPsec, policies LAN ↔ VPN ; FGT-2 dessert la DMZ du WAF.
F5 BIG-IP	Reverse proxy et WAF (LTM + ASM) devant DVWA.
DVWA (Ubuntu 22.04)	Application cible volontairement vulnérable.
Kali externe / Kali Site B	Machines d'attaque (extérieur du réseau et interne via VPN).

Tableau 7 – Rôle des équipements

4 Réalisation

4.1 Interconnexion et routage OSPF

Les interfaces de transit sont configurées dans les sous-réseaux 5.2.1.0/24 (Router ↔ FGT-2) et 5.2.2.0/24 (Router ↔ FGT-3). OSPF est activé en Area 0.0.0.0 sur les trois équipements, chacun avec un Router ID unique. Les LAN 172.30.x.x ne sont volontairement pas annoncés : le trafic inter-sites est ainsi contraint de passer par le tunnel IPsec. Des routes statiques complètent le routage pour joindre les réseaux 172.30.1.0/24 et 172.30.10.0/24 depuis le Router.

Équipement	Router ID	Réseaux annoncés (Area 0.0.0.0)
Router	5.2.1.1	5.2.1.0/24 et 5.2.2.0/24
FGT-2	5.2.1.2	5.2.1.0/24
FGT-3	5.2.2.2	5.2.2.0/24

Tableau 8 – Configuration OSPF

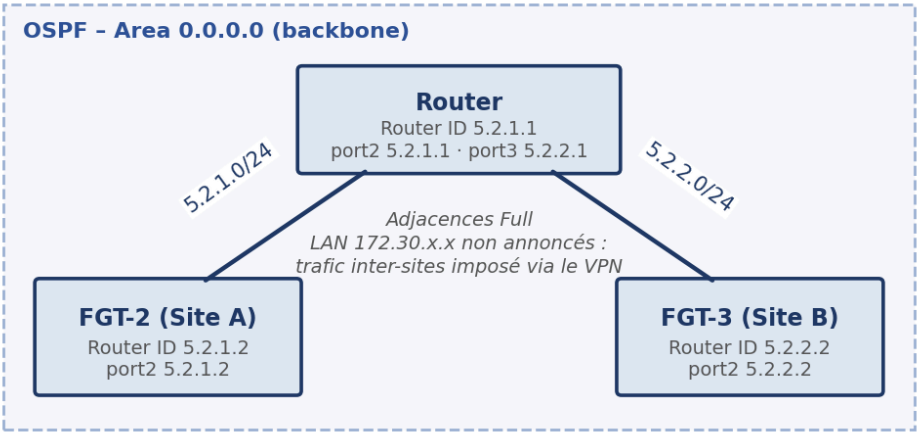


Figure 2 – Routage OSPF en Area 0

Des Security Policies de transit (ACCEPT, NAT désactivé) sont créées sur le Router entre port1 ↔ port2 et port2 ↔ port3 : sur un FortiGate, une route seule ne suffit pas, il faut aussi une policy autorisant le trafic. La table de routage OSPF des FortiGate et la connectivité (ping) entre les équipements de transit valident cette étape.

4.2 Tunnel VPN IPsec entre les deux sites

Le tunnel est de type route-based : `VPN-to-SiteB` sur FGT-2 et `VPN-to-SiteA` sur FGT-3. Il est établi entre les adresses de transit 5.2.1.2 et 5.2.2.2, à travers le Router qui se contente de router le trafic IKE et ESP.

Paramètre	FGT-2 (VPN-to-SiteB)	FGT-3 (VPN-to-SiteA)
Passerelle distante	5.2.2.2 (statique)	5.2.1.2 (statique)
Interface	port2	port2
Authentification	Pre-shared Key, IKEv2	Pre-shared Key, IKEv2
Phase 1	DES / SHA256 – DH 14 et 5	DES / SHA256 – DH 14 et 5
Phase 2 (sélecteur)	172.30.1.0/24 ↔ 172.30.2.0/24	172.30.2.0/24 ↔ 172.30.1.0/24
Phase 2 (algorithmes)	DES / SHA256, PFS (DH 14, 5)	DES / SHA256, PFS (DH 14, 5)
Durée de vie des clés	43 200 s	43 200 s
Routage	Route statique vers le LAN distant via l'interface tunnel	Route statique vers le LAN distant via l'interface tunnel
Security Policies	LAN ↔ VPN, NAT désactivé	LAN ↔ VPN, NAT désactivé

Tableau 9 – Paramètres du tunnel IPsec

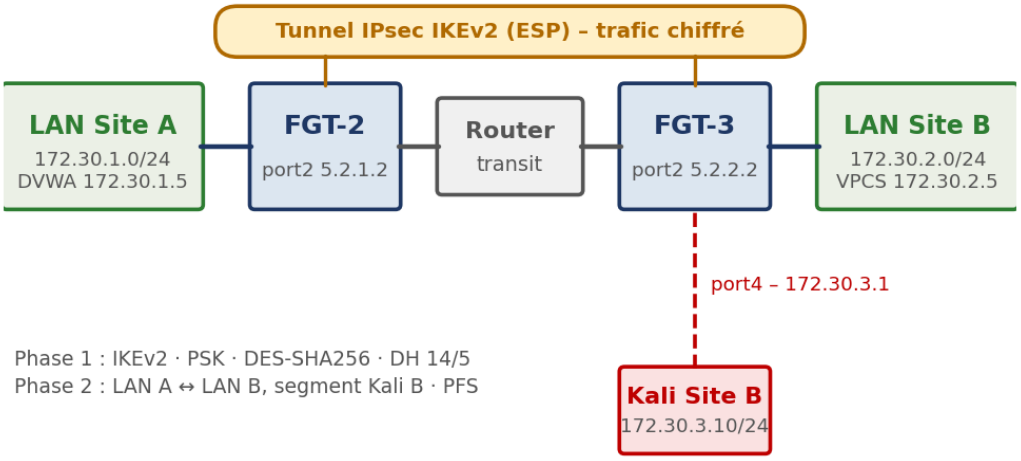


Figure 3 – Tunnel IPsec entre FGT-2 et FGT-3 et segment Kali du Site B

Le chiffrement DES a été retenu car la licence d'évaluation des FortiGate limite les algorithmes disponibles ; cette contrainte est discutée au chapitre 7. L'état du tunnel est vérifié dans le moniteur IPsec et en ligne de commande :

```
diagnose vpn ike gateway list
diagnose vpn tunnel list
```

Un second sélecteur de Phase 2 a été ajouté de chaque côté afin que le segment du Kali du Site B (172.30.3.0/24) puisse emprunter le tunnel vers le réseau applicatif du Site A ; la commande `diagnose vpn tunnel list` affiche alors deux `proxyid`.

4.3 Déploiement de l'application DVWA

Élément	Configuration
Système	Ubuntu 22.04 (image cloud), disque agrandi à 20 Go
Pile logicielle	Apache2, MariaDB, PHP 8.1 (modules mysqli et gd)
Application	DVWA cloné depuis GitHub dans `/var/www/html/dvwa`
Base de données	Base `dvwa` et utilisateur dédié ; création via `setup.php`
Niveau de sécurité	Low
Réseau	`ens3` 172.30.1.5/24 (vers F5) ; `ens4` management et accès Internet
Routes persistantes (netplan)	Retour vers 10.10.10.0/24 et 172.30.10.0/24 via le Self IP du F5 (172.30.1.10)

Tableau 10 – Configuration du serveur DVWA

4.4 Machines d'attaque Kali Linux

Deux machines Kali sont utilisées. Le **Kali externe** (10.10.10.10/24) est placé derrière le Router (port1) et simule un attaquant venant de l'extérieur. Le **Kali du Site B** (172.30.3.10/24) est relié au port4 de FGT-3 : il simule un poste interne compromis qui atteint l'application du Site A à travers le tunnel VPN. Une Security Policy `port4 → VPN` est créée sur FGT-3, avec la policy symétrique sur FGT-2, NAT désactivé.

4.5 Intégration du F5 BIG-IP

Le F5 BIG-IP (version 17.5) est déployé avec 4 vCPU et 5 Go de mémoire. Son interface de management est séparée du trafic applicatif. Il est câblé à FGT-2 par l'interface 1.1 (DMZ) et directement au serveur DVWA par l'interface 1.2 ; le lien direct FGT-2 ↔ DVWA a été supprimé afin de forcer tout le trafic à traverser le WAF.

VLAN	Interface	Tag	Self IP
external	1.1	4093	172.30.10.2/24
internal	1.2	4094	172.30.1.10/24
HA (réservé)	1.3	4092	172.30.20.2/24

Tableau 11 – VLAN et Self IP du F5 BIG-IP

Objet	Paramètre	Valeur
Pool `dvwa_pool`	Membre / moniteur	172.30.1.5:80 / http, Round Robin
Virtual Server `vs_dvwa`	Destination	172.30.10.100/32, port 80
	Profils	tcp, http
	Pool par défaut	`dvwa_pool`
	Source Address Translation	None
Route par défaut	Passerelle	172.30.10.1 (FGT-2 port4)

Tableau 12 – Pool et Virtual Server

Sur FGT-2, la policy `Kali_to_F5_WAF` autorise le trafic HTTP de `port2` vers `port4` à destination de la VIP 172.30.10.100/32. Le Router dispose d'une route statique vers 172.30.10.0/24 via 5.2.1.2. Le chemin applicatif est représenté ci-dessous.

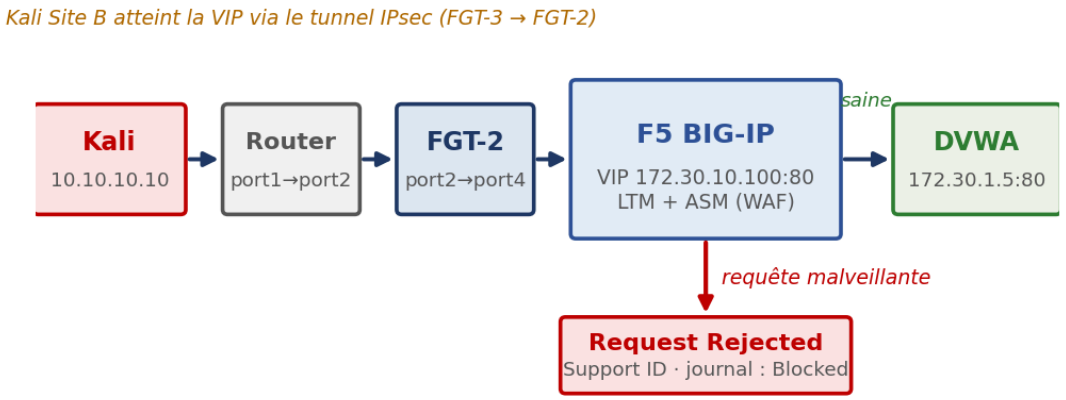


Figure 4 – Chemin des requêtes à travers le F5 BIG-IP

4.6 Politique de sécurité applicative (ASM)

La politique `WAF_DVWA` est associée au Virtual Server. Elle a d'abord été exécutée en mode Transparent, pour observer les attaques sans les bloquer, puis basculée en mode Blocking. Les signatures encore en état Staging n'étant pas appliquées, elles ont été passées en Enforce.

Paramètre	Valeur
Nom / type	`WAF_DVWA` / Fundamental
Langage de l'application	Unicode (UTF-8)
Apprentissage	Automatic, vitesse Fast

Paramètre	Valeur
Précision des signatures	Medium
Mode de fonctionnement	Transparent puis Blocking
Signature SQLi appliquée	SQL-INJ expressions like "OR 1=1" (ID 200002883) – Enforced
Journalisation	Profil Log all requests, stockage local
Consultation	Security → Event Logs → Application → Requests

Tableau 13 – Paramètres de la politique WAF_DVWA

Attaque	Mécanisme de protection ASM
SQL Injection	Signatures d'attaque SQL-INJ
XSS reflected / stored	Signatures d'attaque XSS
Command Injection	Signatures d'exécution de commandes
File Inclusion (LFI)	Signatures de parcours de répertoires (path traversal)
CSRF	Protection CSRF sur les URL concernées
File Upload	Contrôle des types de fichiers et signatures
Brute Force	Protection contre la force brute sur la page de connexion

Tableau 14 – Protections ASM associées aux attaques

5 Tests et résultats

5.1 Scénarios de test

Les mêmes attaques sont rejouées dans quatre scénarios afin de comparer l'effet du WAF et de montrer que le VPN ne protège pas l'application.

Scénario	Source	Cible	WAF
A	Kali externe (10.10.10.10)	DVWA 172.30.1.5	Non
B	Kali Site B (172.30.3.10), via le VPN	DVWA 172.30.1.5	Non
C	Kali externe (10.10.10.10)	VIP 172.30.10.100	Oui
D	Kali Site B (172.30.3.10), via le VPN	VIP 172.30.10.100	Oui

Tableau 15 – Scénarios de test

5.2 Attaques réalisées

Attaque	Exemple de charge utile	Effet observé sans WAF
SQL Injection (bypass)	`1' OR '1'='1`	Tous les utilisateurs affichés
SQL Injection (UNION)	`1' UNION SELECT user, password FROM users -- -`	Condensats MD5 des mots de passe extraits
XSS reflected	`<script>alert('XSS')</script>`	Fenêtre d'alerte exécutée
XSS stored	Script injecté dans le livre d'or	Alerte persistante au rechargement
Command Injection	`127.0.0.1 && whoami`	Utilisateur `www-data` affiché
File Inclusion (LFI)	`?page=../../../../../../etc/passwd`	Contenu de `/etc/passwd` affiché
CSRF	Requête forgée de changement de mot de passe	Mot de passe modifié à l'insu de l'utilisateur
File Upload	Téléversement d'un fichier PHP de test	Fichier accepté par l'application

Attaque	Exemple de charge utile	Effet observé sans WAF
Brute Force	Hydra avec dictionnaire sur le formulaire de connexion	Identifiants valides retrouvés

Tableau 16 – Attaques DVWA et effets sans WAF

5.3 Résultats sans WAF : le VPN ne suffit pas

Dans les scénarios A et B, toutes les attaques aboutissent. Le scénario B est le point clé de la démonstration : le trafic du Kali du Site B traverse le tunnel IPsec, il est donc chiffré et authentifié, mais l'application reçoit des requêtes HTTP parfaitement valides au niveau réseau. Le VPN protège la confidentialité et l'intégrité du lien entre les sites, pas l'application elle-même contre un hôte autorisé ou compromis.

5.4 Résultats avec le WAF F5 BIG-IP

Dans les scénarios C et D, les requêtes passent par la VIP. L'injection SQL a servi de cas d'étude pour documenter chaque étape de la mise en place du WAF.

Étape	Configuration	Résultat
1	Requête HTTP normale	Réponse de DVWA, requête visible dans les journaux
2	Mode Transparent, signature en Staging	Signature SQLi détectée dans le journal, requête autorisée
3	Mode Blocking, signature en Staging	Requête encore autorisée
4	Mode Blocking, signature Enforced	Page « Request Rejected » avec Support ID, journal : Blocked

Tableau 17 – Mise en place du blocage de l'injection SQL

Attaque DVWA	Kali externe sans WAF	Kali Site B (VPN) sans WAF	Kali externe avec WAF	Kali Site B (VPN) avec WAF
SQL Injection	Réussie	Réussie	Bloquée	Bloquée
XSS reflected	Réussie	Réussie	Bloquée	Bloquée
XSS stored	Réussie	Réussie	Bloquée	Bloquée
Command Injection	Réussie	Réussie	Bloquée	Bloquée
File Inclusion (LFI)	Réussie	Réussie	Bloquée	Bloquée
CSRF	Réussie	Réussie	Bloquée	Bloquée
File Upload	Réussie	Réussie	Bloquée	Bloquée
Brute Force	Réussie	Réussie	Bloquée	Bloquée

Figure 5 – Synthèse des attaques avant et après le WAF

5.5 Preuves et journalisation

Chaque requête bloquée est consignée dans Security → Event Logs → Application → Requests. Le Support ID affiché dans la page de rejet permet de retrouver l'événement correspondant.

```
tmsh show ltm pool dvwa_pool
tmsh show ltm virtual vs_dvwa
```

Élément du journal	Information
Requête	URL, méthode et paramètres de la requête reçue
Source	Adresse IP réelle du client (10.10.10.10 ou 172.30.3.10)
Violation	Signature déclenchée (par exemple 200002883)
Action	Blocked (mode Blocking) ou Alerted (mode Transparent)
Support ID	Identifiant unique repris dans la page « Request Rejected »

Tableau 18 – Contenu des journaux ASM

6 Difficultés rencontrées et solutions

La démarche de dépannage a suivi la même logique tout au long du projet : valider d'abord le routage, puis les policies de transit, puis les phases IKE, enfin le trafic réel.



Figure 6 – Démarche de dépannage appliquée

Symptôme	Cause	Solution
Tunnel IPsec « Inactive », message `no policy configured`	Aucune Security Policy ne référençait l'interface VPN	Création des policies LAN ↔ VPN (NAT désactivé)
Phase 2 refusée : `NO_PROPOSAL_CHOSEN`	Propositions de Phase 2 différentes entre FGT-2 et FGT-3	Alignement strict des algorithmes et du PFS
Le Kali du Site B n'atteint pas le Site A	Segment 172.30.3.0/24 absent des sélecteurs de Phase 2	Second sélecteur Phase 2, routes et policies
Le F5 ne joint pas DVWA (ARP sans réponse)	Interface 1.2 branchée sur `e2` alors que 172.30.1.5 est sur `e0`	Recâblage de F5 1.2 vers `e0`
Provisioning ASM refusé	Mémoire insuffisante (4 Go puis 5 Go)	Arrêt des autres nœuds, augmentation de la RAM, provisioning, redémarrage progressif
Timeout de `curl` vers la VIP	Policy FGT-2 `port2 → port4` avec un objet FQDN comme destination	Destination remplacée par la VIP 172.30.10.100/32
Réponses de DVWA perdues	Routes retour vers l'ancienne passerelle 172.30.1.1 (SNAT à None)	Routes pointées vers le Self IP du F5 (172.30.1.10)
SQLi non bloquée en mode Blocking	Signature restée en Staging	Passage de la signature en Enforce

Tableau 19 – Principales difficultés et solutions

7 Limites et perspectives

7.1 Limites de la maquette

- **Chiffrement DES** : imposé par la licence d'évaluation ; il est obsolète et ne doit pas être utilisé en production.
- **SNAT désactivé** sur le Virtual Server : DVWA voit l'adresse réelle du client et nécessite des routes retour vers chaque réseau d'origine.

- **HTTP uniquement** : le trafic entre le client et la VIP n'est pas chiffré (pas de HTTPS ni de SSL offloading).
- **F5 en mode autonome**, avec un seul équipement : pas de haute disponibilité.
- **Policies larges** (service ALL) sur les FortiGate, acceptables en laboratoire mais à restreindre en production.

7.2 Perspectives

- Utiliser AES-256 et SHA-256 avec une licence complète, et migrer vers des groupes Diffie-Hellman modernes.
- Passer le SNAT en Auto Map et activer le chiffrement HTTPS avec SSL offloading sur le F5.
- Ajouter un second BIG-IP pour la haute disponibilité (VLAN HA déjà réservé).
- Affiner la politique WAF (réduction des faux positifs) et centraliser les journaux dans un syslog ou un SIEM.
- Durcir les FortiGate (accès d'administration, policies par service) et tester d'autres niveaux de sécurité de DVWA.

8 Conclusion

Ce projet a permis de construire une architecture réseau complète sur EVE-NG : routage OSPF en Area 0, tunnel IPsec entre deux sites FortiGate, application DVWA et chaîne de protection basée sur un F5 BIG-IP équipé du module ASM.

Les tests montrent qu'un VPN, même fonctionnel, n'empêche pas les attaques applicatives : le Kali du Site B a pu exploiter DVWA à travers le tunnel chiffré. L'ajout du WAF devant l'application a permis de bloquer ces attaques, avec des preuves exploitables dans les journaux (Support ID, signature déclenchée, action Blocked). Le projet confirme l'intérêt d'une défense en profondeur qui associe sécurité réseau et protection applicative.

Il m'a également permis de développer une démarche de dépannage méthodique (routage, policies, IKE, trafic réel) et de me familiariser avec des équipements d'entreprise comme FortiGate et F5 BIG-IP.

Références

[1] OWASP Foundation, « OWASP Top 10 », https://owasp.org/www-project-top-ten/

[2] DVWA – Damn Vulnerable Web Application, https://github.com/digininja/DVWA

[3] F5, documentation BIG-IP (LTM, Application Security Manager / Advanced WAF), https://techdocs.f5.com

[4] Fortinet, FortiOS Administration Guide (IPsec VPN, OSPF, Firewall Policy), https://docs.fortinet.com

[5] IETF, RFC 7296 – Internet Key Exchange Protocol Version 2 (IKEv2), 2014.

[6] IETF, RFC 4303 – IP Encapsulating Security Payload (ESP), 2005.

[7] IETF, RFC 2328 – OSPF Version 2, 1998.

[8] Kali Linux, documentation officielle, https://www.kali.org/docs/

[9] EVE-NG, documentation officielle, https://www.eve-ng.net/